

NGHE LÉN DỮ LIỆU CẢM BIẾN TRONG MẠNG IoT

Đề tài 27 — Học phần Bảo mật IoT (INT4410)

Sinh viên: Thi Võ Hoàng Huy — MSSV 231A010454

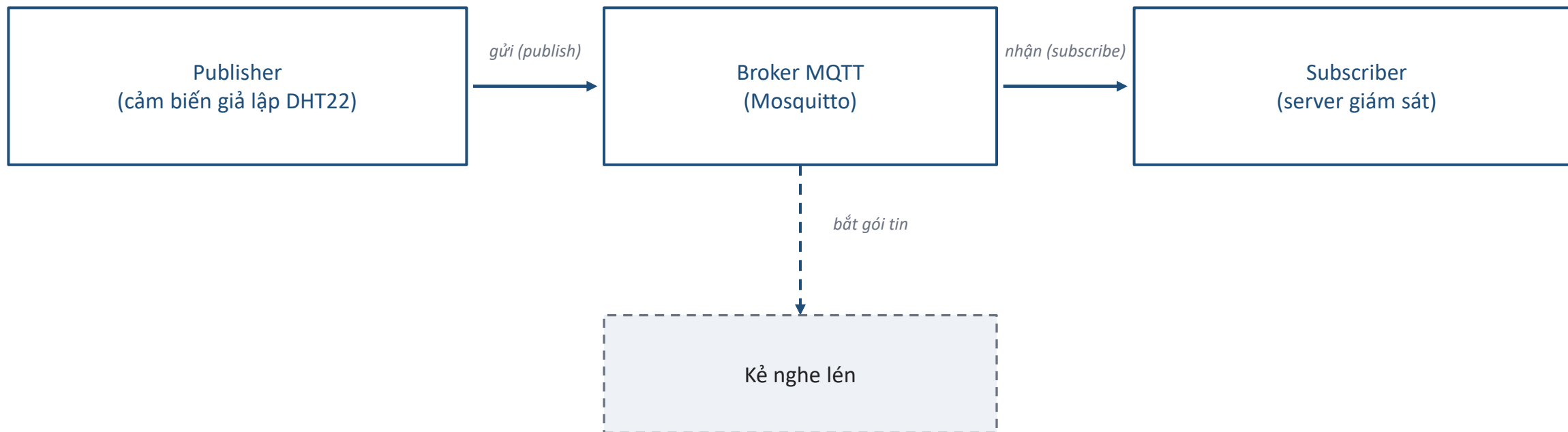
GVHD: Hồ Nhật Minh

Trường Đại học Văn Hiến — Khoa CNTT

Giới thiệu & mục tiêu

- Thiết bị IoT gửi dữ liệu cảm biến qua giao thức MQTT; nhiều nơi truyền dạng thô (cleartext).
- Vấn đề: bất kỳ ai bắt được gói tin trên đường truyền đều đọc được dữ liệu (nghe lén).
- Mục tiêu 1: minh họa bằng thực nghiệm rủi ro nghe lén khi truyền cleartext.
- Mục tiêu 2: so sánh ba mức bảo vệ dữ liệu — cleartext, HMAC-SHA256, AES-256-GCM.
- Mục tiêu 3: kiểm chứng xác thực và phân quyền (ACL) ở tầng broker.
- Mục tiêu 4: phân tích mối đe dọa và đề xuất biện pháp phòng chống.

Kiến trúc & luồng dữ liệu



Dữ liệu nhạy cảm gửi đi: *device_id*, nhiệt độ, độ ẩm. Đường truyền chung nằm ngoài vùng tin cậy — nếu không mã hóa, kẻ nghe lén đọc được toàn bộ.

Ba mức bảo vệ dữ liệu (payload)

Cách gửi	Trên đường truyền	Kẻ nghe lén thấy
Cleartext (gửi thô)	<pre>{ "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2 }</pre>	Đọc được toàn bộ dữ liệu
HMAC-SHA256	<pre>{ "data": {...}, "hmac": "9b1deb4d..." }</pre>	Vẫn đọc được, nhưng sửa là bị phát hiện
AES-256-GCM	<pre>{ iv, ciphertext, tag } — chuỗi Base64</pre>	Chỉ thấy chuỗi vô nghĩa

Xác thực & phân quyền tại broker

- Dựng broker Mosquitto cục bộ trên máy ảo Ubuntu; các client (publisher/subscriber) chạy trên máy Windows — mô hình hai máy.
- Bật xác thực username/password: chỉ tài khoản hợp lệ mới kết nối được.
- Danh sách kiểm soát truy cập (ACL): publisher_user chỉ được GHI, subscriber_user chỉ được ĐỌC trên topic iot/sensor/data.
- Chống giả mạo danh tính: sai mật khẩu → broker từ chối kết nối (Not authorized).
- Chống vượt quyền: tài khoản chỉ có quyền đọc mà cố ghi → bị ACL chặn (Denied PUBLISH).

Tám kịch bản thử nghiệm (TC-01 → TC-08)

Mã	Kịch bản	Kết quả mong đợi
TC-01	Cleartext	JSON dạng rõ — đọc được
TC-02	HMAC hợp lệ	"XÁC THỰC HMAC THÀNH CÔNG"
TC-03	HMAC bị sửa	"XÁC THỰC HMAC THẤT BẠI"
TC-04	AES-256-GCM	Ciphertext + "GIẢI MÃ THÀNH CÔNG"
TC-05	AES-GCM bị phá	"LỖI GIẢI MÃ"
TC-06	Đăng nhập hợp lệ	Truyền dữ liệu bình thường
TC-07	Sai mật khẩu	Từ chối kết nối ("Not authorized")
TC-08	ACL chặn ghi trái phép	"Denied PUBLISH" (mã 135)

Mỗi kịch bản đều có log và ảnh chụp màn hình làm minh chứng.

Kết quả chính

- Cleartext: lộ toàn bộ dữ liệu trên đường truyền.
- HMAC: phát hiện ngay khi gói tin bị sửa.
- AES-256-GCM: đường truyền chỉ còn ciphertext; bị can thiệp → lỗi giải mã.
- Sai mật khẩu: broker từ chối kết nối.
- Sai quyền: ACL chặn ghi (Denied PUBLISH).
- Đủ 8/8 kịch bản chạy thật, có log + ảnh minh chứng.

```
PS C:\Users\USER> cd "D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki"
PS D:\VHU\Tai_Lieu_Hoc_Phan\BAO_MAT_IOT\Bai_cuoi_ki> py src\publisher.py --mode cleartext --broker 192.168.1.6 -
--username publisher_user --password 123 --topic iot/sensor/data
[*] Đang kết nối tới MQTT Broker 192.168.1.6:1883...
[+] Đã kết nối thành công! Đang gửi dữ liệu ở chế độ [CLEARTEXT]...

[Gửi gói tin #1] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:00Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.5, "humidity": 60.2, "s
tatus": "OK"}

[Gửi gói tin #2] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:05Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.6, "humidity": 60.1, "s
tatus": "OK"}

[Gửi gói tin #3] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:10Z", "device_id": "DHT22-SENSOR-001", "temperature": 24.8, "humidity": 60.0, "s
tatus": "OK"}

[Gửi gói tin #4] Topic: iot/sensor/data
Payload gửi đi:
{"timestamp": "2026-07-09T15:40:15Z", "device_id": "DHT22-SENSOR-001", "temperature": 25.0, "humidity": 59.8, "s
tatus": "OK"}
```

Minh họa kịch bản cleartext

Phân tích rủi ro & biện pháp

Mối đe dọa	Biện pháp phòng chống
Nghe lén (Information Disclosure)	Mã hóa AES-256-GCM / bật TLS
Sửa đổi (Tampering)	HMAC-SHA256 / authentication tag của AES
Giả mạo (Spoofing)	Xác thực username/password + ACL ở broker
Phát lại (Replay)	Thêm timestamp / nonce vào bản tin
Lộ khóa	Quản lý khóa ngoài mã nguồn, xoay khóa định kỳ

Đề xuất cấu hình an toàn

- Ưu tiên cao: mã hóa AES-256-GCM ở tầng payload để chống nghe lén và sửa đổi.
- Ưu tiên cao: bật xác thực username/password + ACL trên broker để chống giả mạo và vượt quyền.
- Ưu tiên vừa: bật TLS ở tầng vận chuyển (cổng 8883) để mã hóa toàn bộ kênh MQTT.
- Ưu tiên vừa: quản lý khóa an toàn (không hardcode), xoay khóa định kỳ.
- Nguyên tắc: phòng thủ nhiều lớp — payload + vận chuyển + kiểm soát truy cập.

Kết luận & hướng phát triển

- Đã minh họa rõ rủi ro nghe lén dữ liệu cảm biến khi truyền dạng thô.
- Kiểm chứng thành công HMAC-SHA256, AES-256-GCM và xác thực/ACL qua 8 kịch bản có minh chứng.
- Bốn mục tiêu đề ra đều đạt.
- Hướng phát triển: bật TLS (8883); dùng kho khóa + xoay khóa; thêm cơ chế chống phát lại; mở rộng với thiết bị thật (ESP32, Raspberry Pi).

Mã nguồn & tài liệu tham khảo

Repo GitHub:

github.com/huytvh059/De_tai_27-Nghe_len_du_lieu_trong_mang_IoT

Nguồn tham khảo:

Eclipse Mosquitto · Eclipse Paho MQTT (Python)

RFC 2104 (HMAC) · NIST SP 800-38D (AES-GCM) · OWASP ISVS

Cảm ơn thầy và các bạn đã lắng nghe!